

FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO

REDES DE COMPUTADORES E CIBERSEGURANÇA
PLANO DE GERENCIAMENTO DE RISCOS

Pedro Della Rosa Antônio

Pedro Dimitry Zyrianoff

Lucas Kenichi Soares Abe

Eduardo Chen Zou

Projeto Interdisciplinar - Smart Tennis Arena

Tech Tennis: Plano de Gerenciamento de Riscos

Data: 25/09/2026

Versão: 1.0

1. Introdução

Este relatório descreve como o gerenciamento de riscos e vulnerabilidades será estruturado e realizado para o Tech Tennis. O objetivo é identificar, analisar, planejar respostas e monitorar riscos e vulnerabilidades técnicas, de comunicação, de privacidade e de segurança física, de modo a aumentar a probabilidade de sucesso do projeto e minimizar o impacto de eventos negativos.

A entrega tem como foco a identificação e a documentação das vulnerabilidades do sistema e do código atualmente implementado, o firmware do Arduino Uno responsável por controlar os servomotores, o laser apontador, o buzzer e os LEDs, comandado via protocolo serial. O documento também antecipa riscos relacionados aos módulos ainda não implementados (comunicação Bluetooth via HC-05, aplicativo Android, visão computacional em Python e a API/dashboard web), de forma que as respostas de mitigação possam ser planejadas e efetivamente implementadas na próxima entrega.

2. Metodologia

A abordagem para o gerenciamento de riscos e vulnerabilidades neste projeto será a seguinte:

- **Identificação de Riscos e Vulnerabilidades:** realizada por meio de revisão do código-fonte do firmware Arduino, análise da documentação técnica do projeto (arquitetura, diagrama de conexões e protocolo de comandos), brainstorming com a equipe sobre os componentes ainda não implementados, e comparação com boas práticas conhecidas para sistemas embarcados e dispositivos IoT.
 - **Análise de Riscos:** cada risco identificado é analisado qualitativamente para determinar sua probabilidade e impacto, segundo os critérios definidos nas Seções 6 e 7. Análise quantitativa realizada para os riscos de maior prioridade, quando aplicável.
 - **Planejamento de Respostas:** para cada risco significativo é definida uma resposta planejada (prevenir, transferir, mitigar ou aceitar), a ser efetivamente implementada no código na Entrega 2 da disciplina, que exige relatório complementar com as mitigações aplicadas.
 - **Monitoramento e Controle:** os riscos serão monitorados continuamente ao longo do projeto. O Registro de Riscos será atualizado a cada marco do cronograma do Projeto Interdisciplinar.
-

3. Papéis e Responsabilidades

Papel	Responsabilidades no Gerenciamento de Riscos
Responsável Técnico (Hardware / Embarcados)	Revisar o firmware do Arduino e a arquitetura de hardware em busca de vulnerabilidades; liderar o processo de identificação de riscos técnicos; implementar as mitigações no código embarcado na Entrega 2.
Equipe de Desenvolvimento (App Android, Dashboard, API)	Participar da identificação de riscos nos módulos de software ainda em desenvolvimento (autenticação, Bluetooth, Firebase); aplicar boas práticas de segurança (validação de entradas, criptografia, controle de acesso) conforme cada componente for implementado.
Professor Orientador (Redes de Computadores e Cibersegurança)	Avaliar o relatório de vulnerabilidades, orientar quanto a critérios técnicos de segurança e validar a eficácia das mitigações propostas na Entrega 2.
Partes Interessadas (equipe do PI e futuros usuários)	Fornecer contexto sobre o uso pretendido do sistema (incluindo público infantil) para apoiar a identificação de riscos relacionados à segurança física e à privacidade dos dados.

4. Orçamento e Cronograma para Gerenciamento de Riscos

- **Orçamento:** por se tratar de um projeto acadêmico sem orçamento financeiro formal, os recursos alocados ao gerenciamento de riscos correspondem ao tempo da equipe dedicado às atividades de segurança previstas no cronograma do PI, além de ferramentas gratuitas/open source (ex.: análise estática de código e, quando a API estiver disponível, OWASP ZAP).

- **Cronograma:**

- **Identificação Inicial de Riscos:** 15/09/2026 a 25/09/2026 (Entrega 1).
- **Reuniões de Acompanhamento de Riscos:** semanais, alinhadas às reuniões gerais da equipe do PI.
- **Revisões do Plano de Gerenciamento de Riscos:** a cada entrega da disciplina — Entrega 1 (25/09/2026), Entrega 2 (06/11/2026) e Apresentação (Semana FECAP de Tecnologia).

5. Categorias de Riscos

Os riscos e vulnerabilidades do Tech Tennis serão categorizados da seguinte forma, para facilitar a identificação e a análise:

Categoria	Descrição e exemplos no contexto do Tech Tennis
Técnicos — Hardware / Firmware	Riscos relacionados a componentes eletrônicos e ao código embarcado do Arduino: ausência de validação de entradas, ausência de mecanismo de parada segura, comportamento inesperado dos atuadores (servos, laser).

Técnicos — Comunicação / Rede	Riscos relacionados ao pareamento Bluetooth (HC-05), à futura comunicação Wi-Fi/HTTP da API e do dashboard, e à ausência de criptografia entre os componentes do sistema.
Aplicativo / Software	Riscos relacionados à autenticação, ao armazenamento de credenciais e à integração do aplicativo Android com o Firebase e com o Arduino (módulo ainda em desenvolvimento).
Gerenciais / Organizacionais	Riscos relacionados à concentração de responsabilidades técnicas em poucos integrantes, à dependência de recebimento de componentes e ao cronograma da disciplina.
Privacidade e Conformidade (Externos)	Riscos relacionados à LGPD, especialmente por o sistema poder ser utilizado por crianças, e à futura integração com a plataforma Tech Tennis via API.
Segurança Física correlacionada à Cibersegurança	Riscos relacionados ao uso do laser apontador e dos servomotores, cujo controle remoto indevido ou malicioso poderia causar dano físico ao usuário.

6. Definições de Probabilidade e Impacto

Probabilidade:

Nível	Descrição	Valor
Muito Alta	Quase certo de ocorrer	> 80%
Alta	Provável de ocorrer	61% – 80%
Média	Pode ocorrer	41% – 60%
Baixa	Improvável de ocorrer	21% – 40%
Muito Baixa	Muito improvável de ocorrer	< 20%

Impacto:

Nível	Descrição
Muito Alto	Aumento de mais de 20% no custo/esforço do projeto, ou comprometimento da segurança física do usuário ou de dados pessoais.
Alto	Aumento de 10% a 20% no custo/esforço do projeto, ou exposição relevante de dados/controlado não autorizado do sistema.
Médio	Aumento de 5% a 10% no custo/esforço do projeto.
Baixo	Aumento de 1% a 5% no custo/esforço do projeto.
Muito Baixo	Aumento de menos de 1% no custo/esforço do projeto.

7. Matriz de Probabilidade e Impacto

Esta matriz será utilizada para priorizar os riscos e vulnerabilidades identificados (sessão 8.):

Probabilidade \ Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo	Extremo
Alta	Baixo	Médio	Alto	Alto	Extremo
Média	Baixo	Médio	Médio	Alto	Alto
Baixa	Muito Baixo	Baixo	Baixo	Médio	Médio
Muito Baixa	Muito Baixo	Muito Baixo	Baixo	Baixo	Médio

Extremo / Alto: requerem atenção imediata e um plano de resposta detalhado.

Médio: devem ser monitorados de perto.

Baixo / Muito Baixo: serão monitorados como parte das atividades de rotina do projeto.

8. Registro de Riscos e Vulnerabilidades Identificados

O levantamento abaixo corresponde ao relatório de vulnerabilidades da primeira entrega, elaborado a partir da revisão do firmware Arduino atualmente em funcionamento (via Serial/USB) e da análise da arquitetura documentada para os módulos ainda não implementados. As respostas planejadas para cada item deverão ser efetivamente implementadas e evidenciadas na Entrega 2.

ID	Descrição do Risco / Vulnerabilidade	Categoria	Prob.	Impacto	Nível	Resposta Planejada (Entrega 2)
R01	Ausência de autenticação no protocolo de comandos (Serial/Bluetooth): o firmware aceita qualquer comando de um único caractere (A, D, W, S, L, E, B, R) recebido pela porta serial, sem verificar a identidade de quem envia. Quando o HC-05 for integrado, qualquer dispositivo pareado poderá controlar servos e laser sem autenticação adicional.	Técnico (Firmware / Comunicação)	Alta	Alto	Alto	Implementar handshake/token simples antes de aceitar comandos e restringir comandos sensíveis (laser) a sessões autenticadas.
R02	Configuração padrão do módulo Bluetooth HC-05: módulos HC-05 costumam vir com nome e PIN de pareamento padrão amplamente conhecidos, tornando o pareamento não autorizado plausível para qualquer pessoa próxima.	Comunicação / Rede	Alta	Alto	Alto	Alterar via comandos AT o nome do dispositivo e o PIN padrão do HC-05 antes da integração final.

R03	Ausência de criptografia robusta na comunicação Bluetooth Classic (perfil SPP), permitindo, em tese, interceptação ou repetição de comandos por um dispositivo dentro do alcance do rádio.	Comunicação / Rede	Média	Médio	Médio	Avaliar migração futura para BLE com pareamento seguro ou adicionar assinatura/validação simples nos comandos trocados.
R04	Ausência de validação e de limitação de taxa (rate limiting) na leitura serial: o loop() do Arduino lê continuamente caracteres sem limite de frequência, permitindo o envio excessivo de comandos e comportamento imprevisível dos atuadores.	Técnico (Firmware)	Baixa	Baixo	Baixo	Implementar intervalo mínimo entre comandos aceitos (debounce) e validação adicional de comandos inválidos.
R05	Ausência de mecanismo de parada segura (kill switch): o requisito RF22 do documento do projeto ainda não está implementado; não há comando de emergência que interrompa imediatamente servos e laser em caso de falha ou uso indevido.	Segurança Física / Técnico	Média	Muito Alto	Alto	Implementar comando prioritário de emergência que desliga o laser e trava os servos até reinício explícito, conforme RF22.
R06	Ausência de logs e auditoria de comandos: o firmware atual não registra comandos recebidos, origem ou horário, dificultando a identificação de uso indevido ou falhas (requisito RF23 ainda não atendido).	Técnico / Gerencial	Alta	Baixo	Médio	Registrar localmente (e futuramente via API) os comandos recebidos, respectivo timestamp e resultado.
R07	Segurança física do laser apontador (KY-008): se mal calibrado ou controlado indevidamente (ver R01/R02), o laser pode ser direcionado a uma posição que represente risco ocular ao praticante, especialmente considerando o público infantil citado no projeto.	Segurança Física	Baixa	Muito Alto	Médio	Limitar via software os ângulos possíveis dos servos a uma zona segura, adicionar proteção física/carcaça e verificar a classe de segurança do laser.
R08	Riscos antecipados da futura API/Dashboard (ainda não implementados): ausência prevista de HTTPS/TLS, exposição de tokens/segedos e falta de controle de acesso por perfil (RF01, RF17) caso não sejam considerados desde o início.	Aplicativo / Software (antecipado)	Média	Alto	Alto	Aplicar TLS obrigatório, gestão de segredos e autenticação/autorização por perfil desde o início do desenvolvimento da API.
R09	Proteção de dados de menores (LGPD): o sistema pode ser utilizado por crianças (RF11 e diretrizes de privacidade do projeto), que exigem minimização de dados e proteção reforçada de menores; ainda não há definição de quais dados serão coletados nem como serão protegidos.	Privacidade / Conformidade	Média	Muito Alto	Alto	Mapear os dados pessoais efetivamente coletados, aplicar minimização e consentimento adequado, e restringir o acesso a dados de menores.
R10	Dependência de fornecimento e concentração de responsabilidade técnica: o módulo HC-05 ainda não foi integrado e a responsabilidade pelo hardware está concentrada em um único integrante, representando risco organizacional para o cronograma.	Gerencial / Organizacional	Baixa	Médio	Baixo	Definir plano de contingência (uso temporário via Serial/USB, já funcional) e documentar o conhecimento técnico entre a equipe.

9. Tolerância ao Risco das Partes Interessadas

A equipe do Tech Tennis possui baixa tolerância a riscos que possam comprometer a segurança física dos usuários por exemplo, exposição inadequada ao laser ou movimentação descontrolada dos servomotores e a riscos que envolvam a exposição de dados pessoais, especialmente de crianças e adolescentes, conforme a LGPD e os requisitos de privacidade definidos no documento do projeto (proteção reforçada de menores, coleta mínima e acesso restrito). Por outro lado, a equipe apresenta tolerância moderada a riscos que possam causar pequenos atrasos no cronograma acadêmico, já que o projeto está em fase de protótipo e alguns componentes estão em processo de aquisição e integração.

10. Formatos de Relatórios

- **Registro de Riscos:** mantido abaixo neste documento e, ao longo do projeto, em planilha compartilhada da equipe, com os campos ID, Descrição, Categoria, Probabilidade, Impacto, Nível de Risco, Resposta Planejada, Responsável e Status.

- **Relatório de Status dos Riscos:** será apresentado na Entrega 2 da disciplina, evidenciando quais mitigações foram efetivamente implementadas no código, riscos residuais e novos riscos identificados durante a integração do Bluetooth, do aplicativo, da API e da visão computacional.

11. Acompanhamento

O processo de gerenciamento de riscos será revisado em cada marco do Projeto Interdisciplinar e a cada entrega da disciplina de Redes de Computadores e Cibersegurança (Entrega 1 em 25/09/2026 e Entrega 2 em 06/11/2026), incorporando-se ao relatório final de extensão. O Registro de Riscos é um documento vivo e será atualizado continuamente conforme novos componentes do sistema forem implementados.